Lab 1 — Security Controls Categorization

In this lab you will explore the four **categories** (Technical, Managerial, Operational, Physical) and the six **control types** (Preventive, Deterrent, Detective, Corrective, Compensating, Directive) defined in CompTIA Security+ 1.1. You will then implement a real **technical preventive** control on Linux to make the abstract idea concrete.

Run all commands on the free Killercoda Ubuntu Playground: https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free, installed via apt): - `iptables` (pre-installed) - `auditd`

Step 1 — Build a categorization matrix

Open a scratch file and map ten real-world controls. Use the table below as your answer key after you fill yours in.

Control example	Category	Type
Locked server-room door	Physical	Preventive
"Beware of dog" sign	Physical	Deterrent

Control example	Category	Type
CCTV recording the lobby	Physical	Detective
Fire suppression system	Physical	Corrective
Acceptable Use Policy (AUP)	Managerial	Directive

Control example	Category	Type
Background check on new hire	Managerial	Preventive
Quarterly access review	Operational	Detective
Security awareness training	Operational	Preventive

Control example	Category	Type
Firewall rule `DROP` on port 23	Technical	Preventive
Manual key rotation after a leak	Technical	Compensating

Step 2 — Implement a technical preventive control

Block inbound Telnet (port 23) at the host firewall:

```
iptables -A INPUT -p tcp --dport 23 -j DROP
```

```
iptables -L INPUT -n --line-numbers | head
```

This is **technical** (enforced by software) and **preventive** (it stops the attack before it happens).

Step 3 — Add a detective control on top

Install `auditd` and watch for any changes to a sensitive file (`/etc/passwd`):

```
apt update && apt install -y auditd
```

```
auditctl -w /etc/passwd -p wa -k passwd_changes
```

```
auditctl -l
```

`auditd` is **technical detective** — it does not block, it only records.

Trigger an event and confirm the detection:

```
echo "# test" >> /etc/passwd
```

```
ausearch -k passwd_changes | tail
```

Step 4 — Identify the compensating control

If you cannot patch a legacy system that requires Telnet, what compensating control could you add?

Suggested answer: place the legacy host on an isolated VLAN, allow Telnet **only** from a jump server, and log every session. The isolation + logging compensates for the missing patch.

Free online tools

- **CompTIA control mapping cheatsheet** — https://www.comptia.org/blog/security-controls
- **NIST SP 800-53 control catalog (web)** — https://csrc.nist.gov/projects/risk-management/sp800-53-controls/release-search
- **CIS Controls v8 (free download)** — https://www.cisecurity.org/controls

---

What you learned

- Difference between control **category** (who/what enforces it) and control **type** (what it does).
- How a single risk is usually addressed by a stack of controls (preventive + detective + compensating).
- How to prove a Linux preventive control with `iptables` and a detective control with `auditd`.